

Obsecné principy zajišťování bezpečnosti a dostupnosti digitálních aktiv

Prof. Ing. Cyril Klimeš, CSc.

Základní pojmy

Kyberprostor – 3 vrstvy

- 1) fyzické, (umístění síťových prvků/komponent)
- 2) logické (logické propojení mezi síťovými uzly)
- 3) sociální (osoby na síti – e-mailové adresy, IP adresa, číslo telefonu).

KYBERPROSTOR = INTERNET = **WEBOVÉ SLUŽBY**

- **Kybernetickou bezpečnost** je možné vymezit jako:
 - **souhrn právních, organizačních, technických a vzdělávacích prostředků**, které směřují k zajištění ochrany počítačových systémů a dalších prvků ICT, aplikací, dat a uživatelů,
 - **schopnost počítačových systémů a využívaných služeb reagovat na kybernetické hrozby či útoky a jejich následky**, jakož i plánování obnovy funkčnosti počítačových systémů a služeb s nimi spojených.

Bezpečnost informací

- **Aktivum** (cokoliv, co má pro organizaci hodnotu) - část hodnoceného systému či jeho dat, která mají pro společnost hodnotu.
- **Hrozba** (potenciální příčina nechtěného incidentu, jehož výsledkem může být poškození systému nebo organizace) - jakákoliv aktivita využívající úmyslně či neúmyslně zranitelnosti s negativním dopadem na důvěrnost, dostupnost a integritu aktiv a která je vyjádřena pravděpodobností výskytu hrozby.
- **Zranitelnost** (slabé místo aktiva nebo slabé místo bezpečnostního opatření, které může být zneužito jednou nebo více hrozbami) - vyjádření slabého místa aktiva nebo skupiny aktiv, které za určitého předpokladu bude využito hrozbou s následkem poškození nebo ztráty aktiv a případných procesů/funkcí, které tyto aktiva podporují
- **Riziko = dopad na aktivum × hrozba × zranitelnost**

Aktivum

- **Primární aktiva**, co jsou informace nebo služba, kterou zpracovává nebo poskytuje informační systém kritické informační infrastruktury, komunikační systém kritické informační infrastruktury nebo významný informační systém.
- **Podpůrná aktiva**, což jsou technické aktiva, zaměstnanci a dodavatelé podílející se na provozu, rozvoji, správě nebo bezpečnosti informačního systému kritické informační infrastruktury, komunikačního systému kritické informační infrastruktury nebo významného informačního systému.
 - **Technická aktiva**, což jsou technické vybavení, komunikační prostředky a programové vybavení informačního systému kritické informační infrastruktury, komunikačního systému kritické informační infrastruktury nebo významného informačního systému a objekty, ve kterých jsou tyto systémy umístěny.

Primární aktiva

- **Informační aktiva** - Jedná se o informace, která jsou uložena v informačních systémech a dokumentech společnosti. Bez těchto dat by společnost nebyla schopna účinného rozhodování a nebyla by schopna naplňovat svoje cíle.
- **Služby IT** – Jedná se o informační a komunikační služby, které podporují hlavní činnosti organizace. Tyto služby jsou ve vrcholové úrovni sepsány do Katalogu služeb.
- **Znalosti** – Znalosti představují vědomosti, bez kterých by organizace nemohla úspěšně fungovat. V dnešní době je právě přenos a zachování znalostí (kontinua znalostí) ve firmě zásadní.

Podpůrná aktiva

- **Objekty** – Prostředky pro zajištění fyzické bezpečnosti (např. trezory, zámky, elektronické zóny, bezpečnostní dveře)
- **Technologie** – Softwarové a hardwarové vybavení (neobsahující data)
- **Procesy IT** – Pravidla, principy, postupy a činnosti podporující provoz IT
- **Osoby** – Pracovníci, jež se starají o fungování primárních aktiv (administrátor, programátor, operátor helpdesku)
- **Dodavatelé** – Pracovníci, zajišťující funkcionalitu a funkčnost služeb IT, kteří nejsou zaměstnanci společnosti

Atributy aktiva

- Název (např. server Dell PowerEdge, program GINIS, vedoucí IT)
- Kategorie (primární nebo podpůrné)
- Typ (např. server, účetní systém, vedoucí pracovníci)
- Garant (např. vedoucí IT, vedoucí účtárny)
- Lokalizace (např. Praha, Brno, Fekišovce)
- Hodnocení (Integrita, Dostupnost, Důvěrnost)
- Nadřazená / Podřízená aktiva

Metriky aktiv

- **důvěrnost** (s aktivem může pracovat pouze entita, která k tomu je autorizovaná) - schopnost systému zajistit, aby pouze správný autorizovaný uživatel/systém/zdroj mohl prohlížet, přistupovat, měnit nebo jinak používat data.
- **dostupnost** (aktivum je připraveno v případě potřeby k použití autorizované entitě) - Schopnost systému zajistit, že systémy, informace a služby jsou k dispozici po většinu času.
- **integrita** (aktivum nesmí být změněno, vytvořeno a odstraněno bez autorizovaného přístupu) - Schopnost systému zajistit, aby systém a informace byly přesné a správné.

Zajištění CIA

- **Důvěrnost** - řízení a zaznamenávání přístupu, přenosy informací v komunikační síti chránit pomocí kryptografických prostředků.
- **Dostupnost** – zálohování a obnova, využívání záložních systémů a obnova poskytování služeb je krátkodobá a automatizovaná
- **Integrita** - prostředky, které dovolují sledovat historii provedených změn a zaznamenat identitu osoby provádějící změnu. Ochrana integrity informací přenášených komunikačními sítěmi je zajištěna pomocí kryptografických prostředků

Hrozba

- porušení bezpečnostní politiky, provedení neoprávněných činností, zneužití oprávnění ze strany uživatelů a administrátorů
- škodlivý kód (například viry, spyware, trojské koně)
- narušení fyzické bezpečnosti
- přerušení poskytování služeb elektronických komunikací nebo dodávek elektrické energie
- pochybení ze strany zaměstnanců
- nedostatek zaměstnanců s potřebnou odbornou úrovní
- cílený kybernetický útok pomocí sociálního inženýrství, použití špionážních technik
- napadení elektronické komunikace (odposlech, modifikace)

Zranitelnost

- zastaralost informačního a komunikačního systému
- nedostatečné bezpečnostní povědomí uživatelů a administrátorů
- nedostatečné monitorování činnosti uživatelů a administrátorů a neschopnost odhalit jejich nevhodné nebo závadné způsoby chování
- nedostatečná ochrana aktiv
- nevhodná bezpečnostní architektura
- nedostatečná míra nezávislé kontroly

Další relevantní pojmy

- **Identita** – sada vlastností, které jednoznačně určují konkrétní objekt (věc, osobu, událost)
- **Identifikace** – akt nebo proces, během kterého entita předloží nějaký identifikátor, na jehož základě systém může rozeznat entitu a odlišit ji od jiných entit
- **Autentizace** – proces ověření identity subjektu (autentizace entity, dat, klíče, zprávy)
- **Autorizace** – udělení práv subjektu pro vykonání určených aktivit v IS

Principy kybernetické bezpečnosti

Při uplatňování kybernetické bezpečnosti dochází k implementaci následujících principů, které jsou také nazývány **triády kybernetické bezpečnosti**.

- 1. CIA [C – Confidentiality (důvěrnost); I – Integrity (celistvost); A – Availability (dostupnost)].**
- 2. Prvky kybernetické bezpečnosti (Lidé, Technologie, Procesy).**
- 3. Životní cyklus kybernetické bezpečnosti (Prevence, Detekce, Reakce).**

Kybernetická bezpečnost

- **Smyslem kybernetické bezpečnosti** je zajistit jak **bezpečnost ICT** jako takových, tak i zejména **dat a informací**, které jsou těmito prvky přenášeny, zpracovávány a uchovávány.
- Za tyto významné prvky považujeme **data** a pak samotné **počítačové systémy** (resp. jednotlivé prvky ICT), které umožňují vlastní přenos dat a informací.

Východiska informační/kybernetické bezpečnosti

- Informace představují **majetek (aktivum)** s určitou **hodnotou (*assets*)**.
- Informace musí být chráněna:
 - Před neoprávněným přístupem
 - Před zcizením, zfalšováním a zneužitím
 - Před vyzrazením
 - Před zablokováním přístupu oprávněným subjektům
 -
- Informace je chráněna v souladu s **informační bezpečnostní politikou (BP)** organizace, jejímž je majetkem.

Klasifikace informací

- **dle zákona 412/2005 Sb., o ochraně utajovaných informací a o bezpečnostní způsobilosti:**
 - **Přísně tajné (Top secret)** - neoprávněné nakládání s informacemi by mohlo způsobit mimořádně vážnou újmu zájmům České republiky.
 - **Tajné (Secret)** - neoprávněné nakládání s informacemi by mohlo způsobit vážnou újmu zájmům České republiky.
 - **Důvěrné (Confidential)** - neoprávněné nakládání s informacemi by mohlo způsobit prostou újmu zájmům České republiky.
 - **Vyhrazené (Restricted)** - neoprávněné nakládání s informacemi by mohlo být nevýhodné pro zájmy České republiky.

Klasifikace informací

- **v komerční sféře:**
 - **Chráněné** - neoprávněné nakládání s informacemi by mohlo způsobit závažné poškození či zničení organizace (např. únik strategických informací, zdrojových kódů, schémat zabezpečení, hesel aj.).
 - **Interní** - neoprávněné nakládání s informacemi by mohlo způsobit poškození organizace (např. únik osobních údajů, smluv aj.).
 - **Citlivé** - neoprávněné nakládání s informacemi by mohlo mít negativní dopad na společnost (např. dosud nezveřejněné informace o projektech, plánovaných akcích aj.).
 - **Veřejné** - neoprávněné nakládání s informacemi by nemělo nikoho poškodit a nemělo by mít jakýkoliv dopad na společnost (např. veřejně dostupné kontakty, prezentace projektů aj.).

Traffic Light Protocol

– pro zrychlení výměny informací

Barva	Kdy má být použita	Jak lze sdílet?
Červená: Neurčeno k zveřejnění, Pouze pro účastníky.	v případech, kdy informace neumožňuje účinnou reakci dalších subjektů a mohly by vést k dopadům na soukromí, pověst nebo operace těchto subjektů, pokud by byly zneužity.	informace by měly být vyměňovány pouze verbálně nebo osobně.
Žlutá: Omezené zveřejnění. Zveřejnění je možné jen v organizaci účastníků.	v případech, kdy informace vyžadují účinnou reakci dalších subjektů a přináší riziko pro soukromí, pověst nebo operace, v případě, že jsou sdíleny mimo zúčastněné organizace.	Subjekty mohou volně stanovovat další pravidla sdílení, a tato musí být dodržována.
Zelená: Omezené zveřejnění, Omezené na komunitu.	Pokud jsou informace užitečné pro zvýšení informovanosti všech zúčastněných organizací. Také je možné tyto informace sdílet s dalšími subjekty v rámci širší komunity nebo sektoru.	Informace nesmí být uvolněna mimo komunitu.
Bílá: Zveřejnění není nijak omezeno.	Pokud informace obsahují minimální nebo žádné předvídatelné riziko zneužití v souladu s platnými pravidly a postupy pro zveřejnění.	Informace mohou být distribuovány bez omezení.

Hodnocení důvěrnosti

Úroveň	Popis	Příklad požadavků na ochranu aktiv
Nízká	Aktiva jsou veřejně přístupná nebo byla určena ke zveřejnění. Narušení důvěrnosti aktiv neohrožuje oprávněné zájmy povinné osoby.	Není vyžadována žádná ochrana. Likvidace/mazání aktiva na úrovni Nízká.
Střední	Aktiva nejsou veřejně přístupná a tvoří know-how povinné osoby, ochrana aktiv není vyžadována žádným právním předpisem nebo smluvním ujednáním.	Pro ochranu důvěrnosti jsou využívány prostředky pro řízení přístupu. Likvidace/mazání aktiva na úrovni Střední
Vysoká	Aktiva nejsou veřejně přístupná a jejich ochrana je vyžadována právními předpisy, jinými předpisy nebo smluvními ujednáními (například obchodní tajemství, osobní údaje).	Pro ochranu důvěrnosti jsou využívány prostředky, které zajistí řízení a zaznamenávání přístupu. Přenosy informací komunikační sítě jsou chráněny pomocí kryptografických prostředků. Likvidace/mazání aktiva na úrovni Vysoká
Kritická	Aktiva nejsou veřejně přístupná a vyžadují nadstandardní míru ochrany nad rámec předchozí kategorie (například strategické obchodní tajemství, zvláštní kategorie osobních údajů).	Pro ochranu důvěrnosti jsou využívány prostředky, které zajistí řízení a zaznamenávání přístupu. Dále metody ochrany zabrahující zneužití aktiv ze strany administrátorů. Přenosy informací jsou chráněny pomocí kryptografických prostředků. Likvidace/mazání aktiva na úrovni Kritická

Integrita (Integrity)

- **Integrita dat** je definována jako „jistota, že data nebyla změněna. Přeneseně označuje i platnost, konzistenci a přesnost dat, např. databází nebo systémů souborů. Bývá zajišťována kontrolními součty, hašovacími funkcemi, samoopravnými kódy, redundancí, žurnálováním atd. V kryptografii a v zabezpečení informací všeobecně integrita znamená platnost dat.“
- **Integrita systému** pak je „vlastnost, že systém vykonává svou zamýšlenou funkci nenarušeným způsobem, bez záměrné nebo náhodné neautomatizované manipulace se systémem.“
- **Integrita představuje nemožnost zásahu do informací, dat, počítačových systémů, jejich nastavení atp. jinou osobou, než tou, která je k takovému úkonu oprávněna.**

Hodnocení integrity

Úroveň	Popis	Příklad požadavků na ochranu aktiv
Nízká	Aktivum nevyžaduje ochranu z hlediska integrity. Narušení integrity aktiva neohrožuje oprávněné zájmy povinné osoby.	Není vyžadována žádná ochrana.
Střední	Aktivum může vyžadovat ochranu z hlediska integrity. Narušení integrity aktiva může vést k poškození oprávněných zájmů povinné osoby a může se projevit méně závažnými dopady na primární aktiva.	Pro ochranu integrity jsou využívány standardní nástroje (například omezení přístupových práv pro zápis).
Vysoká	Aktivum vyžaduje ochranu z hlediska integrity. Narušení integrity aktiva vede k poškození oprávněných zájmů povinné osoby s podstatnými dopady na primární aktiva.	Pro ochranu integrity jsou využívány speciální prostředky, které dovolují sledovat historii provedených změn a zaznamenat identitu osoby provádějící změnu. Ochrana integrity informací přenášených komunikačními sítěmi je zajištěna pomocí kryptografických prostředků.
Kritická	Aktivum vyžaduje ochranu z hlediska integrity. Narušení integrity vede k velmi vážnému poškození oprávněných zájmů povinné osoby s přímými a velmi vážnými dopady na primární aktiva.	Pro ochranu integrity jsou využívány speciální prostředky jednoznačné identifikace osoby provádějící změnu (například pomocí technologie digitálního podpisu).

Dostupnost (Availability)

- *„vlastnost přístupnosti a použitelnosti na žádost oprávněné entity.“*
- garance možnosti přístupu k informacím, datům, nebo počítačovému systému v okamžiku potřeby.
- *„O zničení (destruction) určitých informací se v informační bezpečnosti hovoří jako o narušení jejich dostupnosti (availability).“*

Hodnocení dostupnosti

Úroveň	Popis	Příklad požadavků na ochranu aktiv
Nízká	Narušení dostupnosti aktiva není důležité a v případě výpadku je běžně tolerováno delší časové období pro nápravu (cca do 1 týdne).	Pro ochranu dostupnosti je postačující pravidelné zálohování.
Střední	Narušení dostupnosti aktiva by nemělo překročit dobu pracovního dne, dlouhodobější výpadek vede k možnému ohrožení oprávněných zájmů povinné osoby.	Pro ochranu dostupnosti jsou využívány běžné metody zálohování a obnovy.
Vysoká	Narušení dostupnosti aktiva by nemělo překročit dobu několika hodin. Jakýkoli výpadek je nutné řešit neprodleně, protože vede k přímému ohrožení oprávněných zájmů povinné osoby. Aktiva jsou považována za velmi důležitá.	Pro ochranu dostupnosti jsou využívány záložní systémy a obnova poskytování služeb může být podmíněna zásahy obsluhy nebo výměnou technických aktiv.
Kritická	Narušení dostupnosti aktiva není přípustné a i krátkodobá nedostupnost (v řádu několika minut) vede k vážnému ohrožení oprávněných zájmů povinné osoby. Aktiva jsou považována za kritická.	Pro ochranu dostupnosti jsou využívány záložní systémy a obnova poskytování služeb je krátkodobá a automatizovaná.

Prvky kybernetické bezpečnosti

- lidé,**
- technologie,**
- procesy.**

Lidé

- **strůjce (tvůrce) této bezpečnosti** (tj. typicky osoby, které se snaží prosadit a implementovat jednotlivé prvky kybernetické bezpečnosti, ať již ve vztahu k sobě samotnému, či ve vztahu k organizaci),
- **příjemce pravidel kybernetické bezpečnosti** (tj. osoby, které se rozhodly či jsou nuceny implementovat již existující pravidla kybernetické bezpečnosti),
- **subjekty, které je třeba chránit před kybernetickými útoky,**
- **subjekty, které je třeba informovat a proškolit o pravidlech a principech kybernetické bezpečnosti,**
- **riziko či hrozbu v rámci vytváření a udržování kybernetické bezpečnosti.**

Technologie

- **Pro uživatele** - prostředek, který mu umožní **připojit se k Internetu, sociálním sítím a dalším aplikacím**. Je to nástroj, který využívá různé kancelářské balíčky při tvorbě dokumentů, zasílá e-maily, sleduje video aj. Běžný uživatel zpravidla vnímá a interaguje s koncovými technologiemi (PC, tablet, mobilní telefon aj.), které sám osobně využívá, přičemž o další technologické vrstvy, které jsou nezbytné pro jeho činnost v kyberprostoru, se zpravidla nezajímá.
- **Pro organizace** - představují celou škálu zařízení od **technologií určených pro uživatele** (desktop, mobilní zařízení aj.), přes kompletní **infrastrukturu sítě** (LAN, aktivní prvky, Wi-Fi prvky aj.) a služeb (servery, aplikace aj.), po **prvky, které slouží k zajištění zabezpečení** ať již na perimetru (firewall⁷⁷, IDS/IPS⁷⁸, honeypot⁷⁹ aj.), tak v rámci infrastruktury (prvky určené k autentizaci a autorizaci, monitoringu, analýze aj.).
- Je třeba udržovat technologie v takovém stavu, aby byly **schopny reagovat na změny**, které se k vývoji ICT pojí. Zejména by měly být technologie (jak hardware, tak software) udržovány **aktualizované a zabezpečené**.

Procesy

Procesy představují **činnost**, kterou je třeba vynaložit, aby bylo možné **technologie** a s nimi spojené **služby** používat lidmi.

- řízení aktiv a rizik, (definování a kategorizace aktiv, analýza a kategorizace rizik,)
- implementace ICT a aplikací,
- správa uživatelů a rolí,
- autorizace a autentizace,
- údržby (aktualizace) systémů a služeb,
- testování zabezpečení jednotlivých počítačových systémů a služeb,
- analýza nápravných opatření,
- realizace nápravných opatření,
- audit kybernetické bezpečnosti,
- detekce anomálií či kybernetických útoků,
- reakce na kybernetické útoky či jiné incidenty,
- procesy k zajištění kontinuity,
- školení a cvičení atd.

Životní cyklus kybernetické bezpečnosti



System řízení ochrany



Plánuj – Vytvoření.

- Bezpečnostní manažer by měl ve spolupráci s odpovědnými zaměstnanci provádět pravidelné plánování ochranných opatření, jejich implementace, pravidelné interní i nezávislé kontroly a další aktivity v oblasti bezpečnosti. Měl by být vytvořen harmonogram a alokovány kapacity, které umožní plánované aktivity realizovat

Udělej – Implementace a provoz.

- Ve spolupráci s administrátory systémů, zaměstnanci fyzické ochrany, správci procesů či zástupcem administrativní bezpečnosti a dalšími osobami odpovědnými za zvolené oblasti bezpečnosti nebo jejich části by měly být realizována a provozována opatření bezpečnosti, za která jsou tito správci odpovědní.

Zkontroluj – Monitorování a hodnocení.

- Kontrola opatření by měla probíhat jednak v úrovni vyhodnocování bezpečnostních událostí v daných oblastech, ale také přímo kontrolou nastavení jednotlivých opatření a projekce jejich úspěšnosti v oblasti prevence a zjišťování bezpečnostních událostí.

Jednej – Udržování a zlepšování.

- Na základě zjištění získaných pravidelným monitorováním a hodnocením stavu řízení ochrany včetně zohlednění aktuální situace v oblasti legislativních a jiných požadavků na úroveň bezpečnosti a ochrany jsou připraveny aktuální požadavky k úpravě/aktualizaci opatření řízení ochrany ve všech zvolených oblasti řízení bezpečnosti a ochrany

Bezpečnostní politika



- Bezpečnostní politika - účel, cíl, vůle a záměr vedení společnosti v oblasti bezpečnosti - **odpovědět na otázku, proč to děláme.**
- **Standard** - rozpracovává obecné požadavky uvedené v bezpečnostní politice - **poskytnout odpověď na otázku, co se má udělat.**
- **Procedura** - krok za krokem popisuje jak provádět určitou činnost nebo zavést konkrétní opatření- **jak splnit požadavky uvedené ve standardu**

Další dokumenty

- **Guideline**

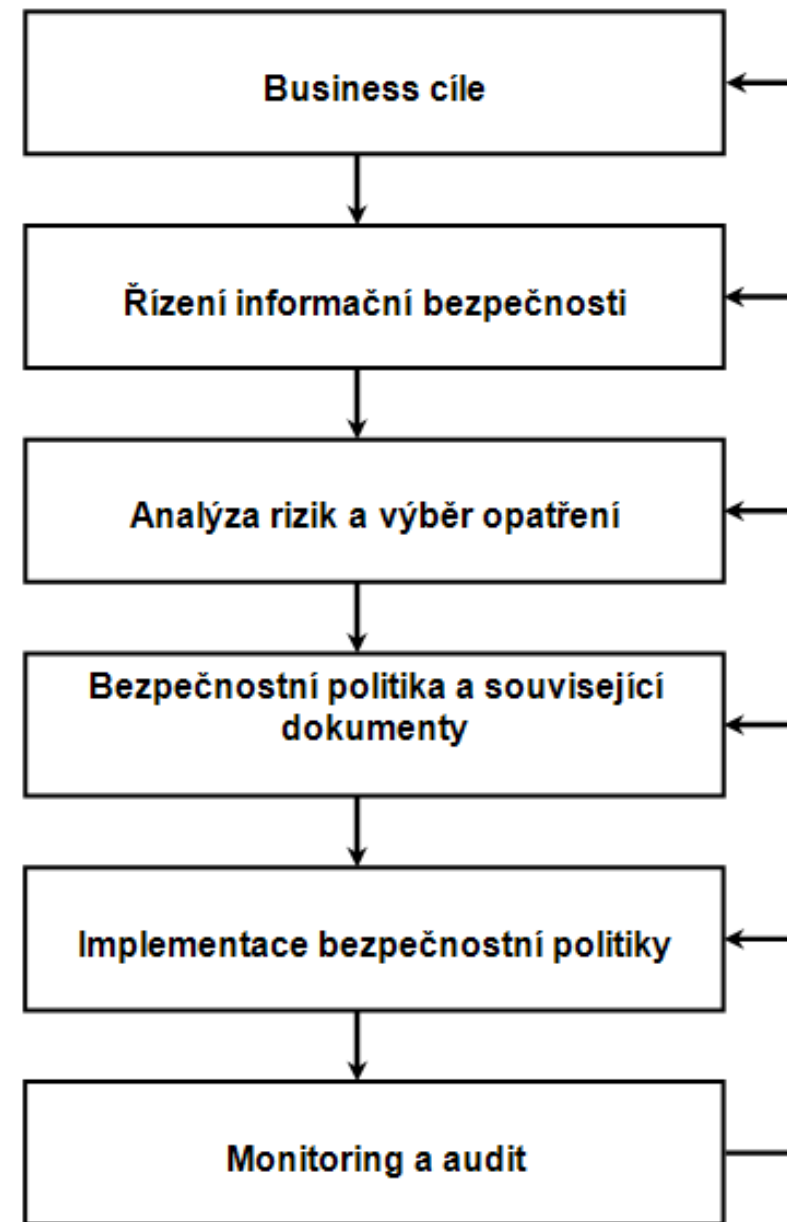
- návod resp. doporučení, jak splnit některé požadavky uvedené ve standardu, např. že heslo by nemělo obsahovat slova ze slovníku, velká písmena na začátku a číslo na konci. Guideline mohou vycházet z doporučení best practice a poskytovat i návod pro vytváření vlastních standardů. Mění se častěji než politika a standard.

- **Baseline**

- definuje požadavky, které musí splňovat každá platforma, systém nebo aplikace, aby byla zajištěna alespoň minimální úroveň bezpečnosti. To je nutné, protože informační systém je tak bezpečný, jak je bezpečný jeho nejslabší článek a dnešní systém se skládá z typicky mnoha různých systémů. V baseline může být uvedeno, že minimální délka hesla je 7 znaků.

Postup tvorby bezpečnostní politiky

- Kvalitní bezpečnostní politika může vzniknout pouze na základě provedené analýzy rizik a porozumění cílům organizace.



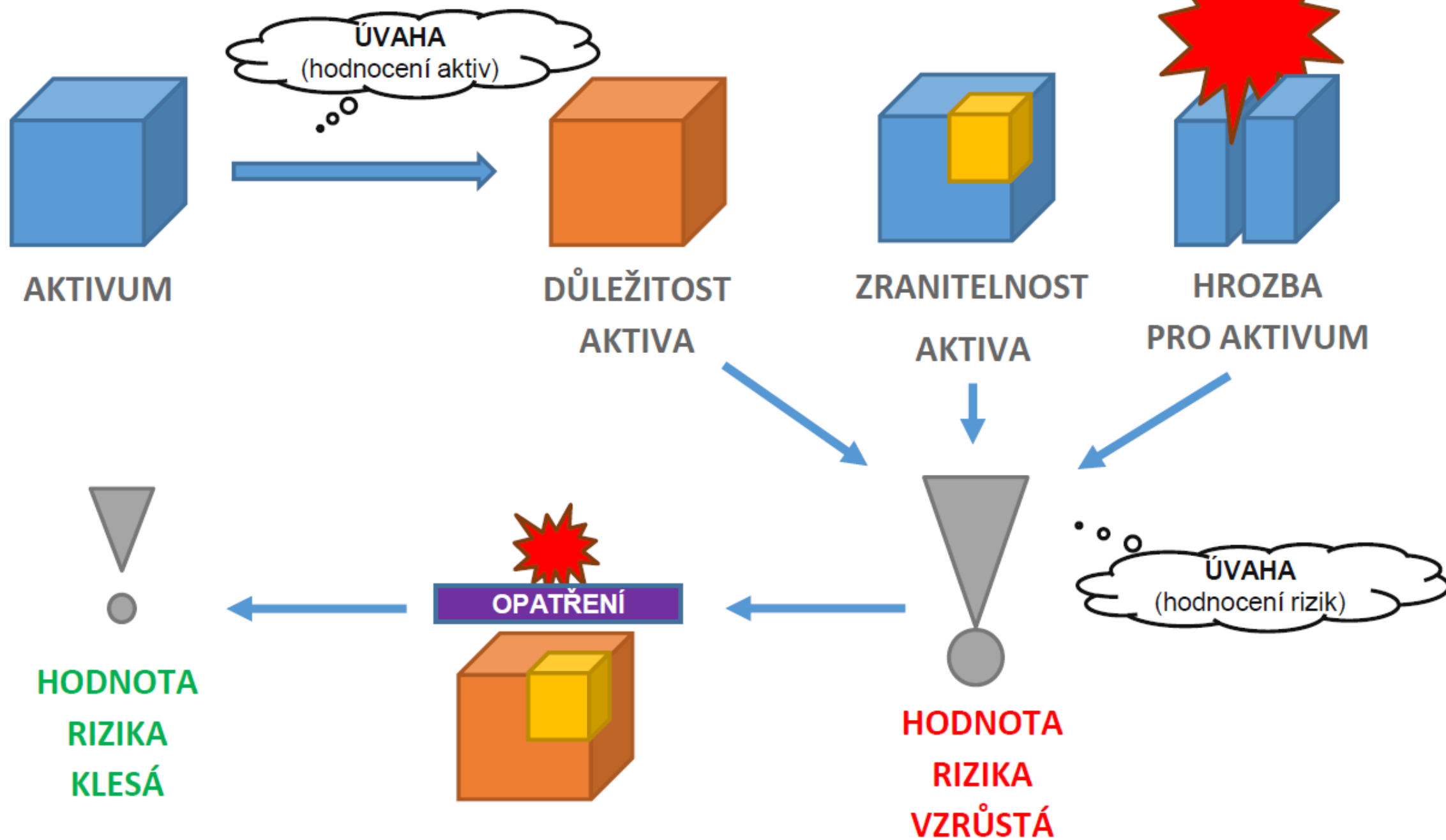
Standardní kroky řešení bezpečnosti

- studie informační bezpečnosti – aktuální stav,
- riziková analýza,
- tvorba bezpečnostní politiky - vytýčení cílů,
- bezpečnostní standardy – pro naplnění cílů bezpečnostní politiky,
- bezpečnostní projekt – technická opatření,
- implementace bezpečnosti – nasazení výše uvedeného,
- monitoring a audit – prověřování, zda vytvořené bezpečnostní mechanismy odpovídají dané situaci.

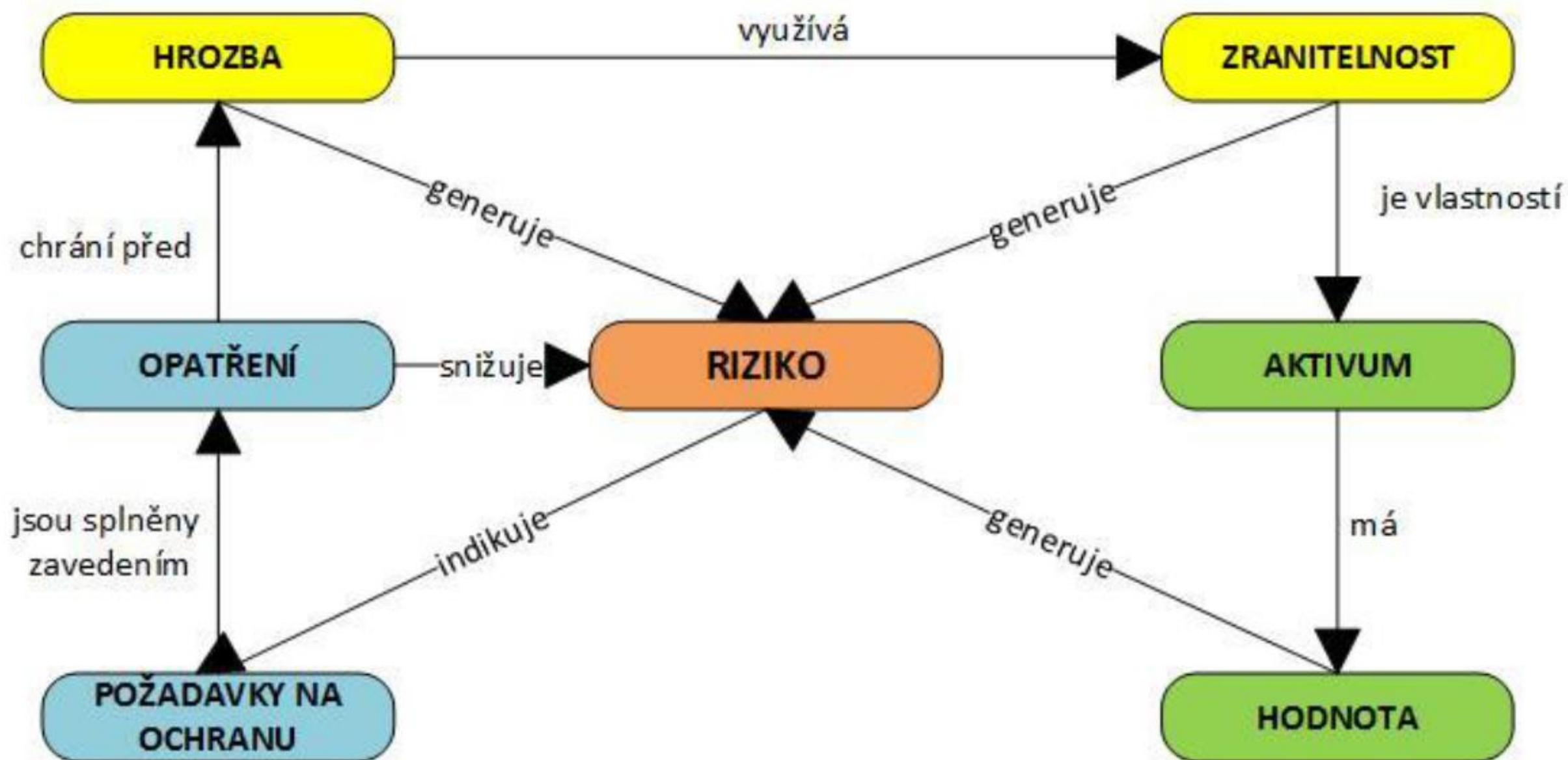
Postup tvorby systému řízení ochrany

- klasifikace a ohodnocení aktiv kritické infrastruktury,
- definice katalogu hrozeb a rizik kritické infrastruktury,
- stanovení katalogu bezpečnostních opatření, včetně jejich kategorizace a parametrů,
- stanovení požadavků a návrh systému řízení ochrany kritické infrastruktury,
- pilotní provoz a ověření funkčnosti systému řízení ochrany kritické infrastruktury na vybrané části,
- vyhodnocení pilotního provozu a úprava metodických postupů,
- tvorba dokumentace pro systém řízení ochrany kritické infrastruktury.

ŘÍZENÍ RIZIK



ŘÍZENÍ RIZIK



Postup při provádění analýzy rizik

1. Identifikace a ohodnocení aktiv - A
2. Nalezení zranitelných míst – kritických oblastí – identifikace hrozeb a jejich pravděpodobností - T
3. Určení zranitelnosti aktiv – V (matice zranitelnosti aktiva hrozbou)
4. Určení míry rizika $R = T * A * V$
5. Stanovení nepřijatelných a přijatelných rizik
6. Stanovení opatření a hodnocení dopadu - identifikace použitelných bezpečnostních opatření ke snížení rizik na přijatelnou míru
7. Odhad ročních úspor po zavedení bezpečnostních opatření (ve vazbě na náklady na opatření – ekonomika)

Případová studie

- <http://bpm-tema.blogspot.com/2007/11/ppadov-studie-analzy-rizik-informan.html>
- Fiktivní firma **WEB-SHOP** se zabývá internetovým prodejem blíže nespecifikovaného zboží. Firma má svou kancelář, odkud je řízena, a sklad prodáváného zboží, který se nachází v jiné lokalitě než kancelář.

- V kanceláři pracuje majitel firmy spolu se sekretářkou. Kancelář má dvě PC.
- Dále je v prostorech kanceláře umístěn server. Tento server je využíván pro provozování www stránek internetového obchodu. Server používá operační systém Microsoft Windows 2000 a databázi Microsoft Access.
- Sklad je přijímacím bodem pro všechny dodavatele, ať se týká přímého dodání k zákazníkovi nebo dodání na sklad.
- Všechny objednávky zákazníků jsou odesílány přímo zákazníkům poštou, s výjimkou určitých velkých nebo těžkých kusů, které jsou zasílány s využitím kurýrní společnosti.
- Sklad má jedno PC, které se používá pro záznam položek na skladu a jejich umístění. Také se používá pro vyznačení objednávek, které mají být odeslány a pro zaznamenávání objednávek, které již byly odeslané. Aplikace pro řízení zásob používá databázi Microsoft Access.
- Dvakrát denně (od pondělí do pátku) se synchronizují záznamy o zásobách a objednávkách se serverem v kanceláři. Přenos souborů a synchronizace je spouštěna z počítače ve skladu. Ve skladu pracují 2 pracovníci a každý z nich může provádět všechny potřebné skladové operace.

Identifikovaná aktiva

nejdůležitější aktiva jsou označena „5“

Typ aktiv	Identifikovaná aktiva	Hodnota aktiva
Informace	Databáze serveru	5
	Databáze skladu	5
HW	Server	4
	PC	2
SW	Operační systémy	3
	Databázové systémy	3
Služby	Připojení serveru	5
	Připojení PC ve skladu	4

Identifikované hrozby a související zranitelnosti

Identifikovaná hrozba	Pravděpodobnost hrozby	Příklad související zranitelnosti
Selhání hardware	3	Náchylnost zařízení na vlhkost, prach a ušpinění
Selhání software	3	Nejasné nebo neúplné specifikace pro vývojáře
Zpronevření aktiv	3	Nedostatek fyzické ochrany budov, dveří a oken
Povodeň	2	Umístění v místech náchylných k povodním
Zlomyslné kódy	5	Nedostatek aktualizací softwaru na ochranu před zlomyslnými kódy
Neúmyslná modifikace	5	Nedostatečný výcvik bezpečnosti
Selhání komunikačních služeb	4	Nechráněná veřejná síťová připojení

Matice zranitelností

	<i>Popis aktiva</i>	Databáze serveru	Databáze skladu	Server	PC	Operační systémy	Databázové systémy	Připojení serveru	Připojení PC ve skladu
	<i>Hodnota aktiva (A)</i>	5	5	4	2	3	3	5	4
<i>Popis hrozby</i>	<i>Pravděpodobnost hrozby (T)</i>								
Selhání hardware	3			2	2				
Selhání software	3					2	2		
Zpronevření aktiv	3			1	3				
Povodeň	2			1	1				
Zlomyslné kódy	5					2	2		
Neúmyslná modifikace	5	2	5						
Selhání komunikačních služeb	4							5	4

Matice rizik

	<i>Popis aktiva</i>	Databáze serveru	Databáze skladu	Server	PC	Operační systémy	Databázové systémy	Připojení serveru	Připojení PC ve skladu
	<i>Hodnota aktiva (A)</i>	5	5	4	2	3	3	5	4
<i>Popis hrozby</i>	<i>Pravděpodobnost hrozby (T)</i>								
Selhání hardware	3			24	12				
Selhání software	3					18	18		
Zpronevěření aktiv	3			12	18				
Povodeň	2			8	4				
Zlomyslné kódy	5					30	30		
Neúmyslná modifikace	5	50	125						
Selhání komunikačních služeb	4							100	64

Výpočet míry rizika. $R = T * A * V$,
kde R je míra rizika,
T je pravděpodobnost vzniku hrozby,
A je hodnota aktiva,
a V je zranitelnost daného aktiva.

Tabulka analýzy rizik

[illegible]

Příklad hodnocení pravděpodobnosti, že riziko nastane

- Nízká pravděpodobnost (NP) – jedná se o pravděpodobnost pod 33 %,
- Střední pravděpodobnost (SP) – jedná se o pravděpodobnost v intervalu 33 – 66 %,
- Vysoká pravděpodobnost (VP) – jedná se o pravděpodobnost nad 66 %.

Příklad hodnocení dopadu

- Malý nepříznivý dopad (MD) – škody do 0,5 % z celkové hodnoty projektu, dopady vyžadují určité zásahy do plánu projektu,
- Střední nepříznivý dopad (SD) – škody v intervalu 0,51 – 19,5 % hodnoty projektu, jedná se o ohrožení nákladů, termínu, respektive zdrojů některé dílčí činnosti, vyžaduje mimořádné zásahy do plánu projektu,
- Velký nepříznivý dopad (VD) – škody nad 20 % hodnoty projektu, jedná se o ohrožení cíle projektu, ohrožení koncového termínu projektu, možnost překročení celkového rozpočtu projektu.

Příklad hodnocení rizik

- Nízká hodnota rizika (NHR) – závažnost a pravděpodobnost rizika neohrožuje projekt, riziko může nastat kdykoliv v průběhu řešení projektu a bude zmírněno nebo odstraněno navrhnutým opatřením,
- Střední hodnota rizika (SHR) – závažnost a pravděpodobnost rizika ohrožuje zpoždění některé z částí projektu, nikoliv projekt jako taký, riziko může nastat kdykoliv v průběhu řešení projektu a bude zmírněno navrhnutým opatřením, nikoliv odstraněno s dopadem na navýšení zdrojů, nákladů nebo odhadové pracnosti,
- Vysoká hodnota rizika (VHR) – závažnost a pravděpodobnost rizika ohrožuje celý projekt, opatření rizika dokážou riziko zmírnit, nikoliv odstranit, riziko navyšuje zdroje, náklady a odhadovanou pracnost, řešení celého projektu je ve zpoždění.

Fyzická, technická a organizační
ochrana infrastruktury

Dělení infrastruktury

- *Nenahraditelnost* – při narušení je nutné subjekt opravit, rekonstruovat nebo znovu vystavět.
- *Nahraditelnost* – při narušení nebo zničení jsou nutné opravy, rekonstrukce nebo znovuvýstavba

Fyzická opatření

- Systémy technické ochrany:
 - poplachový zabezpečovací a tísňový systém,
 - kamerový systém,
 - systém kontroly vstupu,
 - mechanické zábranné prostředky,
- Fyzická ostraha,
- Režimová opatření,
- Kritické prvky komunikační infrastruktury a služeb mají dostatečný výkon a redundanci zajišťující bezproblémový chod

Technická opatření

- Osobní údaje jsou uchovávány v bezpečném prostředí, které je přístupné pouze určeným zaměstnancům.
- Při zpracování osobních údajů (zde při přístupu k nim nebo při jejich přenášení) je používáno šifrování a šifrované protokoly.
- Před přístupem ke svým osobním údajům (datům) nebo jejich úpravou musí uživatel (subjekt údajů) ověřit svou totožnost zadáním svých osobních přihlašovacích údajů.
- Nastavená přísná pravidla pro zálohování osobních údajů uživatelů (a dat obecně) tak, aby byla zajištěna jejich dostupnost, důvěrnost a integrita.
- Provoz je pečlivě a systematicky monitorován, z důvodu včasného a efektivního řešení provozních a bezpečnostních problémů a minimalizovat jejich dopady.
- Provozované systémy jsou průběžně testovány na výskyt zranitelností a jiných slabin v jejich ochraně.

Organizační opatření

- Jsou aplikovány principy minimalizace v oblasti přidělování privilegovaných přístupových oprávnění.
- Jsou aplikována přísná opatření v oblasti správy uživatelských identit a v oblasti autentizace a autorizace.
- Všichni zaměstnanci jsou vázáni principy mlčenlivosti a principy bezpečného nakládání s daty.
- Jsou pořádány školení zaměřené na bezpečnost, která jsou dostupná (a některá i povinná) pro všechny zaměstnance.
- Je jmenován pověřenec pro ochranu osobních údajů, který mimo jiné působí jako poradce v záležitostech ochrany soukromí.
- Jsou zavedeny postupy pro vedení záznamů o zpracovatelských činnostech a hodnocení rizik.
- Jsou uzavřeny dohody o zpracování dat se subdodavateli, kteří zpracovávají data z pověření organizace.

Typický obsah dokumentu politiky bezpečnosti informací

- Důvody, cíle a způsoby zabezpečení informací
- Organizační zajištění bezpečnosti (směrnice)
- Politika mobilních zařízení a práce na dálku
- Personální bezpečnost
- Klasifikace a řízení informačních aktiv
- Fyzické zajištění bezpečnosti (mříže, ostraha) a bezpečnosti prostředí (klimatizace serverovny)
- Vyjasnění práv přístupu k IT systémům
- Minimální požadavky na vývoj a údržbu systémů
- Potřeby a způsoby šifrování
- Způsob zajištění kontinuity činností (business continuity process, BCP)
- Způsob zajištění souladu s legislativou (ISO 27000, GDPR, kybernetický zákon)